

Wprowadzenie do certyfikatów TLS i infrastruktury PKI

1 Wstęp

Certyfikaty TLS (Transport Layer Security) stanowią podstawowy mechanizm zapewniający poufność, integralność oraz uwierzytelnienie w komunikacji sieciowej. Wykorzystywane są m.in. przez protokół HTTPS, który chroni ruch między przeglądarką a serwerem.

2 Infrastruktura klucza publicznego (PKI)

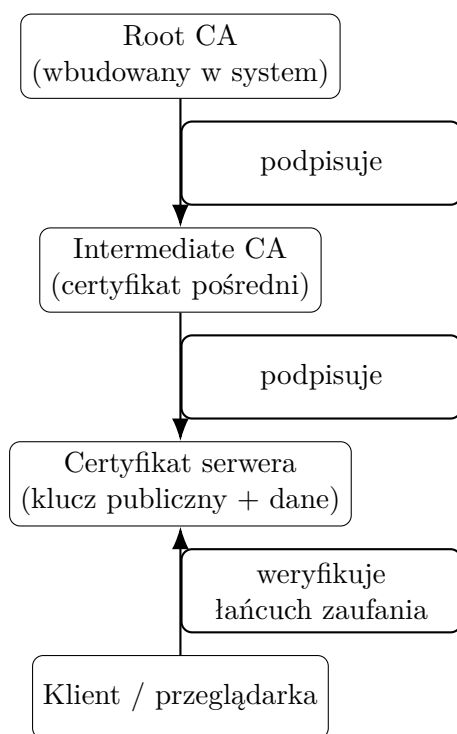
PKI (Public Key Infrastructure) to zestaw technologii, procedur oraz podmiotów, które umożliwiają bezpieczne zarządzanie kluczami publicznymi i certyfikatami cyfrowymi. PKI zapewnia:

- wiarygodną identyfikację podmiotów,
- mechanizm podpisywania i weryfikacji certyfikatów,
- hierarchię zaufania między uczestnikami,
- procedury unieważniania certyfikatów.

Główne elementy PKI to:

- **Root CA** – główny urząd certyfikacji o najwyższym poziomie zaufania,
- **Intermediate CA** – pośrednie urzędy certyfikacji,
- **RA** (Registration Authority) – urząd rejestracji weryfikujący tożsamość podmiotów,
- **Repozytoria certyfikatów i CRL** – listy certyfikatów ważnych i unieważnionych,
- **Podmioty końcowe** – np. serwery HTTPS.

3 Diagram hierarchii zaufania PKI



Rysunek 1: Schemat hierarchii zaufania w infrastrukturze PKI.

4 Klucze publiczne i algorytmy

Certyfikat TLS zawiera klucz publiczny serwera wraz z informacjami identyfikacyjnymi. Najczęściej stosowane algorytmy kryptograficzne to RSA, ECDSA oraz Ed25519. Klucz publiczny służy klientowi do weryfikowania podpisu certyfikatu oraz do bezpiecznej wymiany kluczy sesyjnych.

5 Hierarchia zaufania

System certyfikatów opiera się na hierarchii zaufania PKI. Root CA podpisuje certyfikaty pośrednie, a one certyfikaty końcowe. Przeglądarka ufa certyfikatowi serwera, jeśli może odtworzyć pełny łańcuch zaufania aż do zaufanego Root CA.

6 Generowanie i podpisywanie certyfikatów

Proces tworzenia certyfikatu rozpoczyna się od wygenerowania pary kluczy: prywatnego oraz publicznego. Następnie tworzy się żądanie podpisania certyfikatu (CSR), które zawiera klucz publiczny i dane identyfikacyjne. CSR jest wysyłane do CA, które po weryfikacji informacji podpisuje certyfikat swoim kluczem prywatnym i zwraca gotowy certyfikat TLS.

7 Zastosowanie certyfikatów

Głównym celem certyfikatów TLS jest zapewnienie, że użytkownik łączy się z właściwym serwerem, a komunikacja jest szyfrowana. Bez certyfikatów TLS możliwe byłyby ataki polegające na podszywaniu się pod serwer (np. man-in-the-middle).

8 Certyfikaty self-signed

Certyfikat self-signed (samopodpisany) to certyfikat, który został podpisany własnym kluczem prywatnym właściciela certyfikatu, zamiast kluczem zaufanego urzędu certyfikacji (CA). Oznacza to, że wystawca oraz podmiot certyfikatu są tym samym bytem. Taki certyfikat nadal jest poprawny technicznie — zawiera klucz publiczny, dane oraz podpis — jednak nie należy do globalnej hierarchii zaufania PKI.

8.1 Po co stosuje się certyfikaty self-signed?

Certyfikaty self-signed stosuje się przede wszystkim:

- w środowiskach testowych i deweloperskich,
- w systemach wewnętrznych, gdzie administratorzy ręcznie dodają certyfikat do magazynu zaufanych,
- jako certyfikat główny prywatnego CA (tzw. private PKI).

8.2 Dlaczego przeglądarki zgłaszają błąd?

Przeglądarki mają wbudowaną listę zaufanych Root CA. Ponieważ certyfikat self-signed nie został podpisany przez żaden z nich, nie można zbudować łańcucha zaufania. Przeglądarka nie ma podstaw, by zaufać wystawcy, więc wyświetla ostrzeżenie o możliwym zagrożeniu.

